

Индивидуальный проект

3 Этап

Панина Жанна Валерьевна

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	13
	Список литературы	14

Список иллюстраций

4.1	Скачивание файла с паролями	9
4.2	Запуск сайта DVWA	10
4.3	Получение информации о параметрах cookie	10
4.4	Запрос в Hydra	11
4.5	Ввод данных во вкладке Brute Force	11
4.6	Успешный вход	12

Список таблиц

1 Цель работы

Приобретение практических навыков по использованию инструмента Hydra для брутфорса паролей.

2 Задание

Реализовать эксплуатацию уязвимости с помощью брутфорса паролей.

3 Теоретическое введение

- Hydra используется для подбора или взлома имени пользователя и пароля.
- Поддерживает подбор для большого набора приложений [brute].

Пример работы:

Исходные данные: IP сервера 178.72.90.181; Сервис http на стандартном 80 порту;

Для авторизации используется html форма, которая отправляет по адресу `http://178.72.90.181/cgi-bin/luci` методом POST запрос вида `username=root&password=test_password`; В случае неудачной аутентификации пользователь наблюдает сообщение `Invalid username and/or password! Please try again`. Запрос к Hydra будет выглядеть примерно так:

```
hydra -l root -P ~/pass_lists/dedik_passes.txt -o
./hydra_result.log -f -V -s 80 178.72.90.181 http-post-form
"/cgi-bin/luci:username=^USER^&password=^PASS^:Invalid
username"
```

Используется `http-post-form` потому, что авторизация происходит по http методом post. После указания этого модуля идёт строка `/cgi-bin/luci:username=USER&password=PASS:Invalid username`, у которой через двоеточие (:) указывается:

- путь до скрипта, который обрабатывает процесс аутентификации (`/cgi-bin/luci`);
- строка, которая передаётся методом POST, в которой логин и пароль заменены на ^{USER} и ^{PASS} соответственно (`username=USER&password=PASS`);

- строка, которая присутствует на странице при неудачной аутентификации; при её отсутствии Hydra поймёт, что мы успешно вошли (Invalid username).

4 Выполнение лабораторной работы

1. Чтобы пробрутфорсить пароль, нужно найти список частоиспользуемых паролей, например, я нашла в открытом источнике - стандартный список паролей для kali rockyou.txt (рис. 4.1).

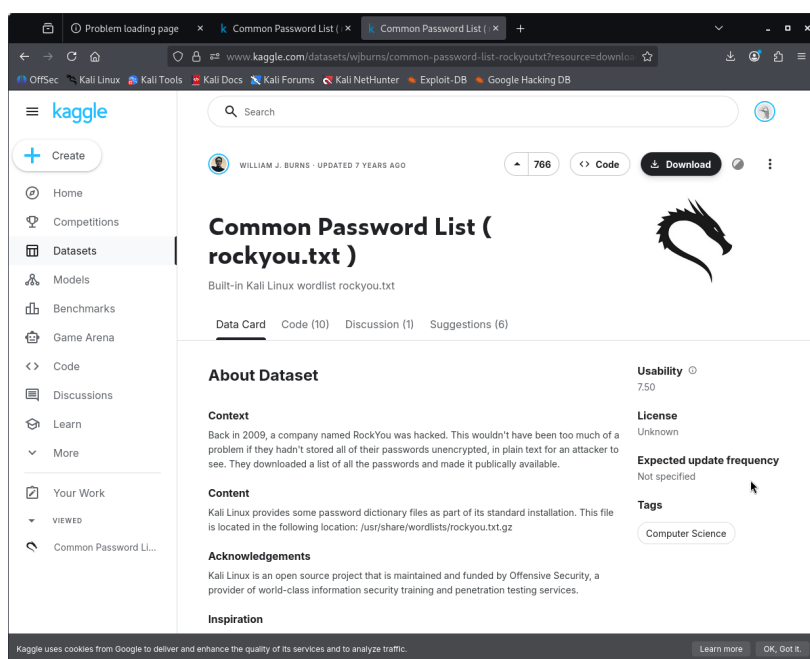


Рисунок 4.1: Скачивание файла с паролями

2. Захожу на сайт DVWA, предварительно запустив в терминале apache2 и mysql (рис. 4.2).

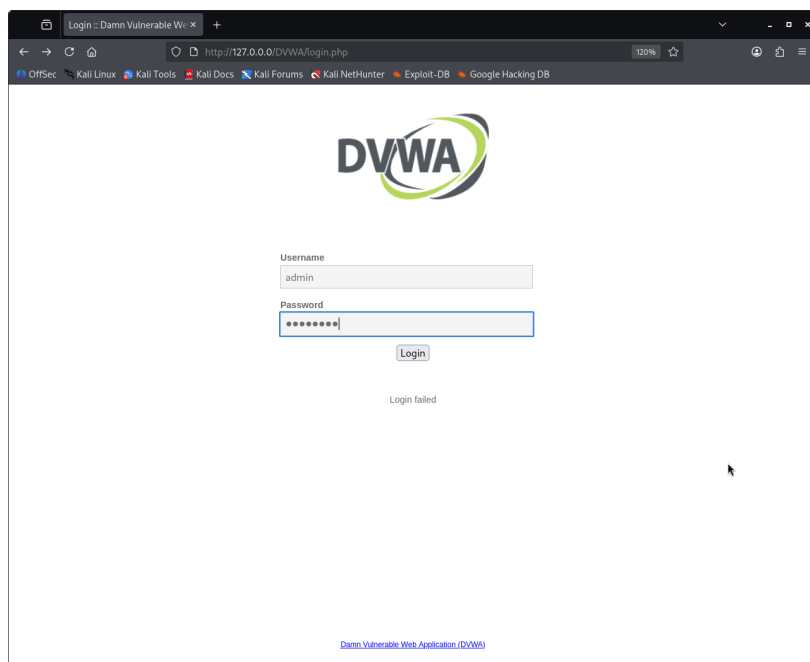


Рисунок 4.2: Запуск сайта DVWA

3. Для запроса hydra нужны параметры cookie с этого сайта. Для получения информации о файлах cookie нажимаю F12 и открываю вкладку „Storage“ и копирую PHPSESSID и security (рис. 4.3).

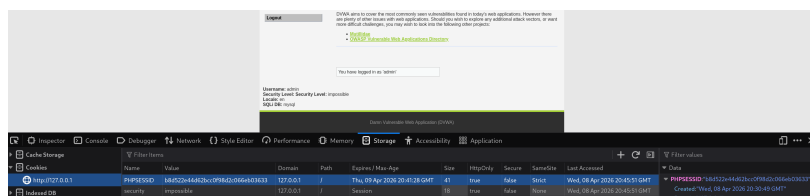


Рисунок 4.3: Получение информации о параметрах cookie

4. Ввожу соответствующий запрос в Hydra. Подбираю пароль для пользователя admin, использую GET-запрос с двумя параметрами: безопасность и PHPSESSID (рис. 4.4). Через некоторое время появляется результат с подходящими паролями.

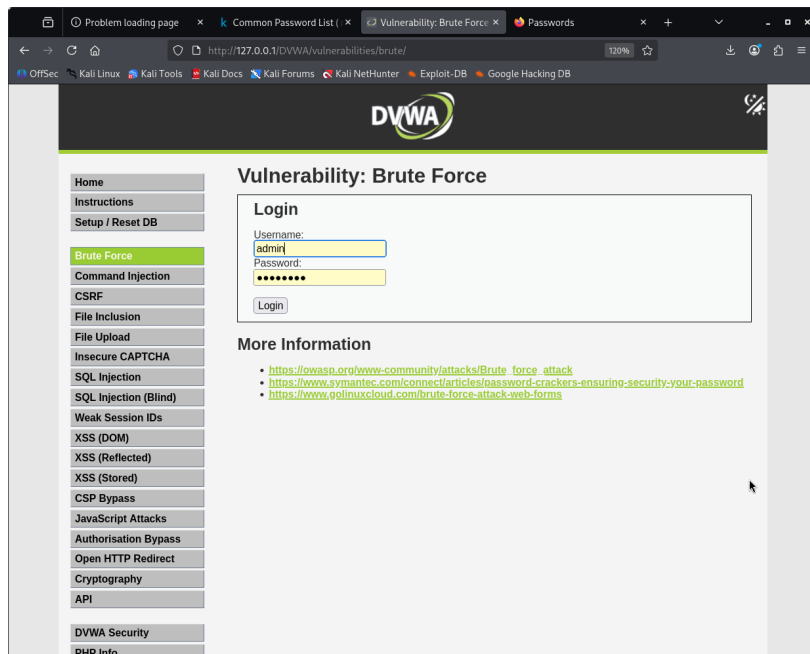


Рисунок 4.6: Успешный вход

5 Выводы

В ходе выполнения работы я приобрела практические навыки по использованию инструмента Hydra для брутфорса паролей.

Список литературы